

中华人民共和国通信行业标准

YD/T ××××—××××

电信网和互联网 数据安全风险评估实施方法

Data security risk assessment implementation for telecommunications and Internet

（报批稿）

××××-××-××发布

××××-××-××实施

中华人民共和国工业和信息化部 发布

目 次

前 言	III
1 范围	1
2 规范性引用文件	1
3 术语和定义	1
4 数据安全风险评估概述	1
4.1 数据安全风险评估原则	1
4.1.1 关键数据原则	1
4.1.2 场景依赖原则	2
4.1.3 可控性原则	2
4.2 风险评估各要素之间的关系	2
4.3 风险评估原理	3
4.4 数据安全风险评估流程	4
5 数据安全风险评估实施	5
5.1 评估工作准备	5
5.1.1 确定评估目标	5
5.1.2 确定评估范围	5
5.1.3 组建评估团队	6
5.1.4 组织数据安全相关工作调研	6
5.1.5 确定评估依据	6
5.2 数据资产识别	6
5.2.1 数据调研	6
5.2.2 数据重要程度分析与赋值	7
5.2.3 确定待评估的数据资产范围	7
5.3 数据应用场景识别	7
5.4 数据威胁识别	8
5.4.1 概述	8
5.4.2 数据威胁分类	8
5.4.3 数据威胁属性分析与赋值	9
5.5 脆弱性识别	12
5.5.1 概述	12
5.5.2 脆弱性分类	12
5.5.3 脆弱性属性分析与赋值	13
5.6 已有安全措施识别	14
5.7 数据安全威胁与脆弱性利用关系	14
5.8 风险分析与评价	14
5.8.1 概述	14
5.8.2 风险分析模型	14
5.8.3 风险计算	15

5.8.4 风险结果评价.....	16
5.8.5 风险评估报告.....	16
6 风险处置.....	17
7 残余风险评估.....	18
附录 A（资料性附录）数据安全有关法律法规及标准参考表.....	19
附录 B（资料性附录）数据应用场景中的业务流程或使用流程举例.....	21
附录 C（资料性附录）数据威胁与脆弱性利用关系示例.....	22
参考文献.....	23

前 言

本标准是“电信网和互联网安全防护体系”系列标准之一。该系列标准预计结构及名称如下：

- 1、《电信网和互联网安全防护管理指南》
- 2、《电信网和互联网安全等级保护实施指南》
- 3、《电信网和互联网安全风险评估实施指南》
- 4、《电信网和互联网灾难备份及恢复实施指南》
- 5、《固定通信网安全防护要求》
- 6、《移动通信网安全防护要求》
- 7、《互联网安全防护要求》
- 8、《增值业务网—消息网安全防护要求》
- 9、《增值业务网—智能网安全防护要求》
- 10、《接入网安全防护要求》
- 11、《传送网安全防护要求》
- 12、《IP 承载网安全防护要求》
- 13、《信令网安全防护要求》
- 14、《同步网安全防护要求》
- 15、《支撑网安全防护要求》
- 16、《非核心生产单元安全防护要求》
- 17、《电信网和互联网物理环境安全等级保护要求》
- 18、《电信网和互联网管理安全等级保护要求》
- 19、《固定通信网安全防护检测要求》
- 20、《移动通信网安全防护检测要求》
- 21、《互联网安全防护检测要求》
- 22、《增值业务网—消息网安全防护检测要求》
- 23、《增值业务网—智能网安全防护检测要求》
- 24、《接入网安全防护检测要求》
- 25、《传送网安全防护检测要求》

- 26、《IP 承载网安全防护检测要求》
- 27、《信令网安全防护检测要求》
- 28、《同步网安全防护检测要求》
- 29、《支撑网安全防护检测要求》
- 30、《非核心生产单元安全防护检测要求》
- 31、《电信网和互联网物理环境安全等级保护检测要求》
- 32、《电信网和互联网管理安全等级保护检测要求》
- 33、《域名系统安全防护要求》
- 34、《域名系统安全防护检测要求》
- 35、《网上营业厅安全防护要求》
- 36、《网上营业厅安全防护检测要求》
- 37、《WAP 网关系统安全防护要求》
- 38、《WAP 网关系统安全防护检测要求》
- 39、《电信网和互联网信息服务业务系统安全防护要求》
- 40、《电信网和互联网信息服务业务系统安全防护检测要求》
- 41、《增值业务网 即时消息业务系统安全防护要求》
- 42、《增值业务网 即时消息业务系统安全防护检测要求》
- 43、《域名注册系统安全防护要求》
- 44、《域名注册系统安全防护检测要求》
- 45、《移动互联网应用商店安全防护要求》
- 46、《移动互联网应用商店安全防护检测要求》
- 47、《互联网内容分发网络安全防护要求》（本标准）
- 48、《互联网内容分发网络安全防护检测要求》
- 49、《互联网数据中心安全防护要求》
- 50、《互联网数据中心安全防护检测要求》
- 51、《移动互联网应用安全防护要求》
- 52、《移动互联网应用安全防护检测要求》
- 53、《公众无线局域网安全防护要求》
- 54、《公众无线局域网安全防护检测要求》

- 55、《电信网和互联网安全防护基线配置要求及检测要求 网络设备》
- 56、《电信网和互联网安全防护基线配置要求及检测要求 安全设备》
- 57、《电信网和互联网安全防护基线配置要求及检测要求 操作系统》
- 58、《电信网和互联网安全防护基线配置要求及检测要求 数据库》
- 59、《电信网和互联网安全防护基线配置要求及检测要求 中间件》
- 60、《电信网和互联网安全防护基线配置要求及检测要求 WEB 应用系统》
- 61、《电信和互联网用户个人电子信息保护通用技术要求和管埋要求》
- 62、《电信和互联网用户个人电子信息保护检测要求》
- 63、《互联网接入服务安全防护检测要求》
- 64、《网络交易系统安全防护要求》
- 65、《网络交易系统安全防护检测要求》
- 66、《邮件系统安全防护要求》
- 67、《邮件系统安全防护检测要求》
- 68、《公有云服务安全防护要求》
- 69、《公有云服务安全防护检测要求》
- 70、《电信网和互联网大数据平台安全防护要求》
- 71、《电信网和互联网大数据平台安全防护检测要求》
- 72、《电信网和互联网数据安全风险评估实施指南》

本标准按照 GB/T1.1-2009 给出的规则起草。

请注意本文件的某些内容可能涉及专利，本文件的发布机构不承担识别这些专利的责任。

本标准由中国通信标准化协会提出并归口。

本标准主要起草单位：中国信息通信研究院，国家计算机网络应急技术处理协调中心，中国移动通信集团公司，中国联合网络通信集团公司，北京神州绿盟信息安全科技股份有限公司，北京世平信息科技有限公司，启明星辰信息技术集团股份有限公司，上海观安科技有限公司，成都思维世纪科技有限责任公司。

本标准主要起草人：魏亮，陈湑，刘明辉，张玮，陈亮，江为强，孙艺，孙叶，刘德林，张晓娜，王腾腾，王赓，刘晓光。

电信网和互联网数据安全风险评估实施方法

1 范围

本标准提供以数据为核心保护对象的面向应用场景的风险评估方法论，规定了电信网和互联网数据安全风险评估的基本原则、基本要素及各要素之间的关系、实施流程、风险分析模型与方法。

本标准适用于电信网和互联网组织开展数据安全风险自评估工作，同时适用于第三方专业测评机构开展数据安全风险评估工作。

2 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 20984-2007 信息安全技术 信息安全风险评估规范

ISO GUIDE 73:2009 风险管理 词汇表 (Risk management — Vocabulary)

3 术语和定义

ISO GUIDE 73:2009，GB/T 20984-2007中界定的以及下列术语和定义适用于本文件。

3.1

风险评估 risk assessment

风险识别、风险分析和风险评价的全过程。

3.2

风险识别 risk identification

发现、认识和描述风险的过程。

3.3

风险分析 risk analysis

理解风险的本质和确定风险水平的过程。

3.4

风险评价 risk evaluation

将风险分析结果与风险准则进行比较，以确定风险和/或其大小是否可接受或可容忍的过程。

3.5

数据可控性 data controllability

组织对向外传输、共享的数据具有控制能力，对数据接收方组织的数据保护能力可衡量，对接收方接收数据后的活动及其再转移行为可约束、可监控、可撤消。

4 数据安全风险评估概述

4.1 数据安全风险评估原则

4.1.1 关键数据原则

数据安全风险评估应以业务中重要程度较高的数据资产作为评估工作的核心，把这些数据涉及的各类应用场景作为评估的重点。数据重要程度越高，数据安全事件一旦发生对业务或组织的影响程度越大，

应将重要程度较高的数据资产作为评估工作的重点对象，评估其在各应用场景中存在的威胁、脆弱性及相关安全风险。

4.1.2 场景依赖原则

数据安全风险评估工作依赖数据所涉及的各应用场景。

被评估数据的安全风险与其应用场景强相关，评估数据安全风险应评估数据在所涉及的各类应用场景下的安全风险。数据安全风险评估工作首先需要梳理数据所涉及的各类应用场景。然后在此基础上进一步分析数据应用时在场景中各主体及各主体间的活动可能存在的安全风险。

4.1.3 可控性原则

风险评估的可控性原则如下：

a) 风险评估服务可控性：评估人员应事先被评估组织管理者的认可，明确需要得到被评估组织协作的工作内容，明确评估工作中相关的管理和技术人员任务，获得支持和配合，确保安全评估工作的顺利进行。

b) 人员与信息可控性：所有参与评估的人员应签署保密协议，以保证项目信息的安全；应对工作过程数据和结果数据严格管理，未经授权不得泄露给任何单位和个人。

c) 过程可控性：应按照项目管理要求，成立项目实施团队，项目组长负责制，达到项目过程的可控。

d) 工具可控性：安全评估人员所使用的评估工具应该事先通告被评估组织，并获得其许可。

e) 对业务影响可控：从项目管理层面和工具技术层面，将评估工作对网络及相关系统正常运行的可能影响降低到最低限度。对于需要进行攻击性测试的工作内容，需与被评估组织沟通并进行应急备份，同时选择避开业务的高峰时间进行。

4.2 风险评估各要素之间的关系

数据安全风险评估中各要素的关系如图1所示。

数据安全风险评估的原理如图2所示，数据安全风险评估包括数据资产、数据应用场景、数据威胁、脆弱性、安全措施五个基本要素。每个要素有各自的属性，数据资产的属性是数据重要程度；数据威胁的属性数据应用场景中数据威胁发生可能性；脆弱性的属性是数据应用场景中脆弱性可利用性和脆弱性影响程度；安全措施的属性是和脆弱性的关联性。数据安全风险评估的主要内容为：

a) 风险识别阶段：

- 1) 识别数据资产并分析其重要程度；
- 2) 对数据应用场景进行识别；
- 3) 识别数据应用场景中数据威胁，并判断数据威胁发生可能性；
- 4) 识别数据应用场景中脆弱性，与具体安全措施关联分析后，判断脆弱性可利用程度和脆弱性对数据资产影响的严重程度。

b) 风险分析阶段：

- 1) 根据数据威胁与脆弱性利用关系，结合数据威胁发生可能性与脆弱性可利用性判断安全事件发生的可能性；
- 2) 根据脆弱性影响严重程度及数据重要程度计算安全事件影响严重程度；
- 3) 根据安全事件发生的可能性以及安全事件影响严重程度，判断风险值。

c) 风险评价阶段：

根据风险接受准则判定风险是否可以接受。



图2 数据安全风险评估原理

4.4 数据安全风险评估流程

图3给出数据安全风险评估的流程，第5章将围绕风险评估流程阐述数据安全风险评估的具体实施步骤。

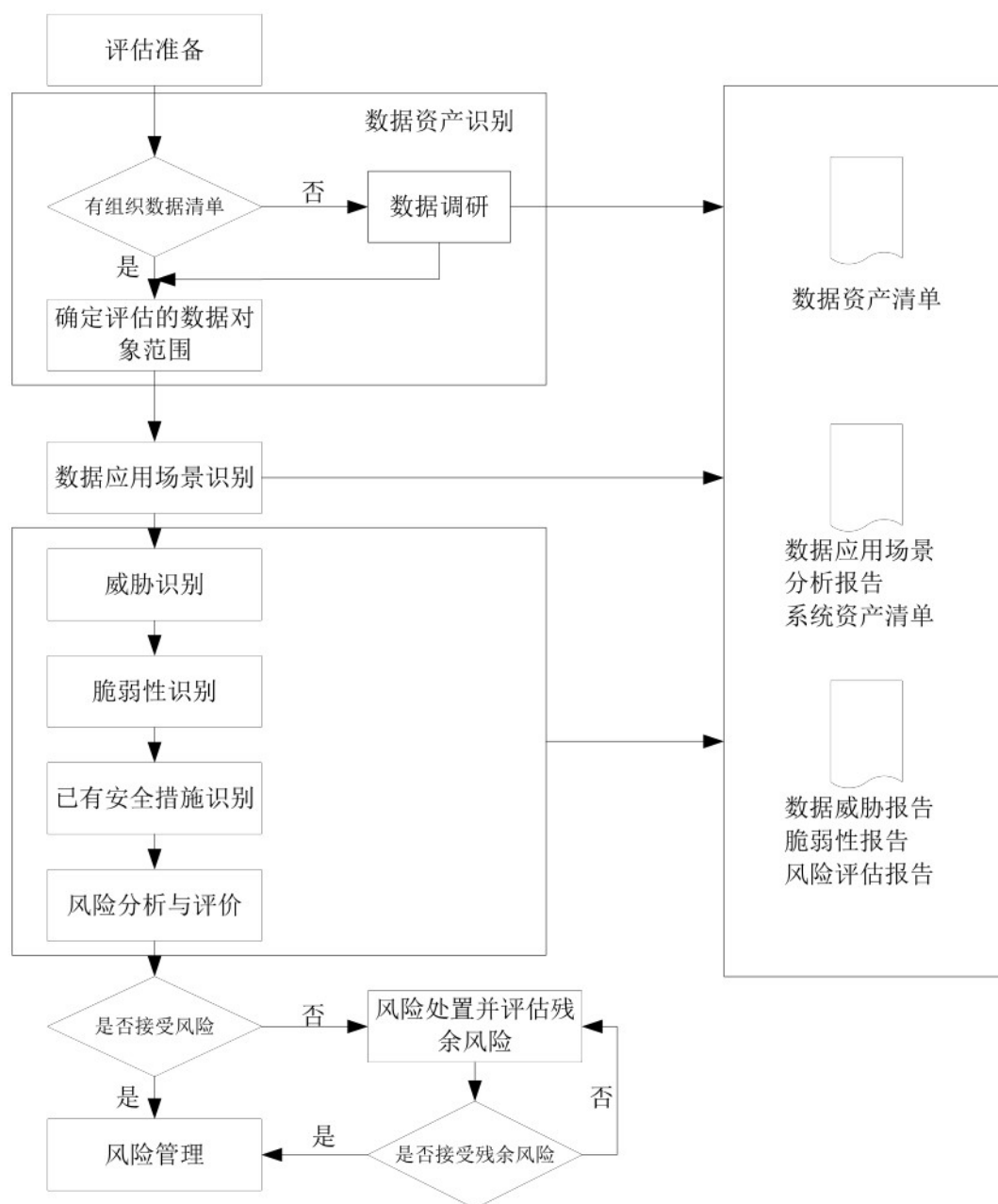


图 3 数据安全风险评估实施流程图

5 数据安全风险评估实施

5.1 评估工作准备

5.1.1 确定评估目标

数据安全风险评估专注于被评估业务的数据安全风险,保障被评估业务的数据资产(包含个人信息)的机密性、完整性、可用性、可控性。评估内容包括数据资产、数据应用场景、面临威胁、脆弱性以及已有安全措施等各方面。

5.1.2 确定评估范围

数据安全风险评估工作范围可能是组织全部的业务及业务相关的各类信息系统，也可能是某个独立的业务及相关信息系统等，评估对象为根据关键数据原则确定的业务的数据资产。

5.1.3 组建评估团队

应组建适当的风险评估团队，以支持整个风险评估过程的推进，以及评估工作的有效开展。该团队可由组织管理层、法务、安全、相关业务骨干、技术和管理等人员组成。必要时可以聘请相关专业的专家组成专家小组。当被评估组织委托网络安全服务机构开展数据安全风险评估时，应与被委托单位共同组建评估团队。

5.1.4 组织数据安全相关工作调研

风险评估团队应对被评估组织的数据安全相关工作进行充分调研，调研内容包括但不限于：

- a) 数据安全组织管理组织架构、职责和人员配备情况；
- b) 数据安全组织管理相关制度、流程；
- c) 待评估业务相关的信息系统的网络拓扑结构与安全域划分；
- d) 其他。

调研可采取问卷调查、访谈、资料查阅等方式进行。

5.1.5 确定评估依据

风险评估团队应确定被评估组织适用的评估依据，包括：

- a) 适用的法律、行政法规、司法解释；
- b) 电信主管部门、国家网信部门、公安机关等有关部门规章、规范性文件；
- c) 现行有关国际标准、国家标准、行业标准；
- d) 被评估组织的数据安全、信息安全等有关安全要求。

附录A给出了数据安全有关法律、行政法规、司法解释、部门规章、规范性文件、国家标准、行业标准的参考。

5.2 数据资产识别

5.2.1 数据调研

在确定评估范围基础上，针对评估范围内的每项业务，识别业务涉及的数据资产。

业务尚未建立数据资产清单情况下，可通过如下方法开展数据调研：首先应识别业务逻辑、业务功能、业务流程步骤等内容，然后识别各业务功能、流程相关信息系统，再调查信息系统收集、存储、使用了哪些业务数据。识别业务数据类型、数据所在位置、数据量、保存方式（信息系统、终端、文档服务器）等内容。

本阶段评估人员应输出数据资产清单，包括数据类型、数据所在位置等内容。如果组织已有数据资产清单，评估人员需判断清单是否真实、完整。

本阶段评估工作输出件为数据资产清单。

5.2.2 数据重要程度分析与赋值

数据重要程度是数据资产的属性。数据重要程度可从国家安全与社会公共利益影响、企业利益影响、个人权益影响等维度分析。

从国家安全与社会公共利益层面考虑,数据分级可根据一旦发生安全事件会对国家安全、社会秩序、经济建设和公众利益造成可能的影响严重程度与范围进行分级。

从企业利益层面考虑,数据可从业务影响、财务影响、声誉影响等方面进行分级。

- a) 业务影响应考虑数据安全事件发生后对生产业务造成的影响。
- b) 财务影响应考虑数据安全事件发生后导致的财务损失。包括:直接损失(收入受损、缴纳罚款、赔偿金或其他资产损失等)和恢复成本(比如恢复数据、恢复业务、消除影响、安抚/挽回客户等涉及的资金或人工成本等)。
- c) 声誉影响应考虑数据安全事件发生后被外界所知所造成的声誉受损,包括客户信任度、客户流失率、企业形象、行业声誉、社会认同感等。

从个人权益层面考虑,数据可根据敏感程度、影响范围进行分级。

为保持风险计算的一致性,本标准对数据重要程度赋值为五级,等级1-5级分别对应数据重要程度很低、低、中等、高、很高。

5.2.3 确定待评估的数据资产范围

在上述数据调研结果基础上,根据关键数据原则选择重要程度较高的数据资产作为评估的重点。评估人员可根据实际需求选择是否评估重要程度中低的数据资产。

5.3 数据应用场景识别

确定待评估的数据对象后,针对每一类待评估的数据对象,识别其涉及的各类应用场景。

数据应用场景识别包括识别业务流程或使用流程、相关数据活动、参与主体。

业务流程或使用流程举例参见附录B。

数据活动包括但不限于数据提取、数据获取、数据整合、数据分析、结果存储、数据下载、数据外发、结果展示等。

流程各环节参与主体包括人员、内外部系统、内外部接口等。

人员包括外部使用者,如用户、客户、合作伙伴、项目合作人员、供应商、服务商等;内部使用者,如销售人员、市场营销人员、管理人员、IT服务人员及其他相关使用者等。人员根据数据角色分类,可以分为业务(数据)需求方、数据分析人员、业务部门人员、第三方服务人员、IT服务人员等。

内外部系统包括:数据存储系统,如数据库服务器、文件服务器、云平台、员工存储终端等;数据处理使用系统,如业务系统、业务后台、移动应用端、员工办公终端设备等;数据分析系统,如大数据分析系统等;管理系统,如统一身份认证平台、数据权限平台、中间层平台、VPN管理系统等。

内外部接口包括上述内部系统接口、外部系统接口、外部流程接口等。外部流程包括统一账号管理流程、统一数据权限管理流程等。

本阶段风险评估工作应输出数据应用场景分析报告和系统资产清单。

5.4 数据威胁识别

5.4.1 概述

威胁是一种对资产构成潜在破坏的可能性因素，是客观存在的。对于数据资产来说，数据威胁是指可能导致危害数据机密性、完整性、可用性、可控性的安全事故发生的潜在起因。数据威胁识别，主要分析数据在应用场景流转过程可能影响数据机密性、完整性、可用性、可控性的威胁类型，并进一步分析其属性，包括攻击动机、攻击能力、威胁发生概率，并对其属性进行赋值。本阶段评估工作应输出数据威胁报告。

5.4.2 数据威胁分类

数据威胁有多种分类方法，表1给出了一个数据在应用场景流转过程的不同阶段可能受到威胁的分类，评估人员可根据此分类对应用场景中可能存在的数据威胁进行分析。

表1 数据威胁分类识别表

数据生命周期阶段	数据威胁分类	数据威胁描述
数据采集	恶意代码注入	数据入库时，恶意代码随数据注入到数据库或信息系统，危害数据机密性、完整性、可用性
	数据无效写入	数据入库时，数据不符合规范或无效
	数据污染	数据入库时，攻击者接入采集系统污染待写入的原始数据，破坏数据完整性
	数据分类分级或标记错误	数据分类分级判断错误或打标记错误，导致数据受保护级别降低
数据传输	数据窃取	攻击者伪装成外部通信代理、通信对端、通信链路网关通过伪造虚假请求或重定向窃取数据
	网络监听	有权限的员工、第三方运维与服务人员接入，或攻击者越权接入内部通信链路网关、通信代理监听数据；攻击者接入外部通信链路网关、通信代理、通信对端监听数据
	数据篡改	攻击者伪装成通信代理或通信对端篡改数据
数据存储	数据破坏	由于信息系统自身故障、物理环境变化或自然灾害导致的数据破坏，影响数据完整性和可用性
	数据篡改	篡改网络配置信息、篡改系统配置信息、篡改安全配置信息、篡改用户身份信息或业务数据信息等，破坏数据完整性和可用性
	数据分类或标记错误	数据分类分级或相关标记被篡改，导致数据受保护级别降低
	数据窃取	在数据库服务器、文件服务器、办公终端等存储系统安装恶意工具窃取数据
	恶意代码执行	故意在数据库服务器、文件服务器、员工终端等存储系统上执行后门、病毒、木马、蠕虫、窃听软件、间谍软件等恶意程序或代码，窃取、篡改或破坏数据

	数据不可控	依托第三方云平台、数据中心等存储数据，没有有效的约束与控制手段
	数据不可控	在使用云计算或者其他技术时，数据存放位置不可控，导致数据存在境外数据中心，数据和业务的司法管辖关系发生改变
数据共享	共享数据未脱敏	与第三方机构共享数据时，第三方机构及其人员可以直接获取敏感元数据的调取、查看权限
	共享权限混乱	与第三方机构共享数据时，接口权限混乱，导致第三方能访问其它未开放的数据
	数据过度获取	由于业务对数据需求不明确，或未实现基于业务人员与所需要数据的关系的访问控制，业务人员获取超过业务所需的数据，容易造成数据泄露
	数据不可控	数据可被内部员工获取，组织对内部员工对所获数据的保存、处理、再转移等活动不可控； 数据可被第三方服务商、合作商获取，组织对第三方机构及其员工对所获数据的使用、留存、再转移等活动未约束或不掌握； 数据共享给恶意的第三方机构
数据处理	注入攻击	数据处理系统可能遭到恶意代码注入、SQL注入等攻击，造成信息泄露，危害数据机密性、完整性、可用性
	数据抵赖	人员访问数据后，不承认在某时某刻用某账号访问过数据
	使用权限混乱	处理系统调用数据接口权限混乱，导致能访问其它未开放的数据
	数据过度获取	由于相关业务对数据需求不明确，或未实现基于业务人员、系统与所需要数据的关系的访问控制，导致业务人员或处理系统获取超过业务所需数据，容易造成数据泄露
	数据不可控	依托第三方机构或外部处理系统处理数据，没有有效的约束与控制手段
	敏感元数据未脱敏使用	处理系统可直接调取敏感元数据，容易导致信息泄露
数据销毁	数据到期未销毁	数据失效或业务关闭后，遗留了敏感数据仍然可以被访问，破坏了数据的机密性
	数据未正确销毁	被销毁数据通过技术手段可恢复，破坏数据的机密性

5.4.3 数据威胁属性分析与赋值

5.4.3.1 概述

数据威胁要素属性包括数据威胁动机、能力及频率。分析出具体数据威胁后，需要进一步分析数据威胁的属性。根据威胁可能的来源分析其攻击动机、攻击能力，根据调查分析威胁发生概率。数据威胁发生可能性的赋值将由数据威胁动机赋值、能力赋值及频率赋值共同确定。

5.4.3.2 数据威胁源动机及其能力

动机、能力是数据威胁的属性。不同类型威胁的可能来源不同，威胁来源可分为人为因素和非人为因素。根据威胁的动机，人为因素又可分为恶意和非恶意两种。环境因素包括自然界不可抗的因素和其它物理因素。威胁作用形式可以是对数据应用场景中参与主体（网络与信息系统）直接或间接的攻击，也可能是参与主体（人员、网络与信息系统）发起的偶发或蓄意的事件。

从威胁动机来看，人为的安全威胁又可细分为非恶意行为和恶意攻击行为。非恶意行为主要包括粗心或未受到良好培训的管理员和用户，由于特殊原因而导致的无意行为，造成对信息系统的破坏。恶意攻击是指出于各种目的而对信息系统实施的攻击。恶意攻击具有明显的目的性，一般经过精心策略和准备，并可能是有组织的，并投入一定的资源和时间。

不同的危险源具有不同的攻击能力，攻击者的能力越强，攻击成功的可能性就越大。衡量攻击能力主要包括：施展攻击的知识、技能、经验和必要的资金、人力和技术资源等。

表 2 提供了一种威胁来源的分类方法。

表2 数据威胁源类型、动机和能力示例

分类	类型	描述	主要动机	能力
非人为	自然灾害	非人为不可抗的自然灾害,比如水灾、台风、地震、雷击、坍塌、火灾、恐怖袭击、战争等	具有一定预测性	自然灾害的威胁程度不等,可能会对信息系统造成毁灭性的破坏
	环境因素	断电、静电、灰尘、潮湿、温度、鼠蚁虫害、电磁干扰、意外事故等环境危害	无动机,具有一定预测性	威胁程度不等
	技术局限性	由于设备自身的软硬件故障、系统本身设计缺陷或软件缺陷等	无动机无预测性	威胁程度不等
人为	非恶意行为	粗心或未受到良好培训的管理员和用户	无动机无预测性,或能力不足	掌握内部情况,具有数据访问权限,或掌握可利用的账户信息,由于特殊原因而导致的无意行为或误操作,可以从内部破坏信息系统及数据
	内部恶意员工	主要指对机构不满或具有某种恶意目的的内部员工	由于对机构不满而有意破坏数据,被收买或威胁窃取或破坏数据,或出于某种目的窃取数据或破坏数据	掌握内部情况,具有数据合法访问权限,或掌握可利用的账户信息,可以从内部获取数据
	独立黑客	主要指个体黑客	企图寻找并利用系统的脆弱性,以达到满足好奇心、检验技术能力以及获取、恶意破坏数据等目的,动机复杂,目的性不强	占有少量资源,一般从外部侦察并攻击网络和系统;攻击者水平高低差异很大
	有组织的攻击者	国内外竞争者	主要指具有竞争关系的国内外工业和商业机构	获取商业情报,窃取数据资源,破坏竞争对手的业务和数据,目的性较强
				具有一定的资金、人力和技术资源,通过多种渠道搜集情报,包括利用竞争对手内部员工、独立黑客以至犯罪团伙

	犯罪团伙	主要指黑灰产犯罪团伙。对犯罪行为可能进行长期的策划和投入	偷窃、诈骗钱财，窃取机密信息，贩卖个人信息	具有一家的资金、人力和技术资源，实施网络犯罪，对犯罪有精密计划和准备
	恐怖组织	主要指国内外恐怖组织	恐怖组织通过强迫或恐吓政府或社会，以满足其需要为目的，采用暴力或暴力威胁方式制造恐慌	具有丰富的资金、人力和技术资源，对攻击行为可能进行长期策划和投入，可能获得敌对国家的支持
	外国政府	主要指其它国家或地区设立的从事军事、情报等窃取的机构	从其它国家搜集政治、经济、军事情报或机密信息，或获取大量其他国家个人信息进行舆论诱导，目的性极强	组织严密、具有充足的资金、人力和技术资源，通过多种渠道，包括技术能力、威逼利诱内部员工窃取信息，将窃取信息、攻击信息系统作为战争手段

根据数据在业务发展战略中的定位、数据重要性和数据经济价值，将数据威胁动机划分为五个不同的等级，等级 1-5 级，分别对应很低、低、中等、高、很高。

根据威胁来源的威胁能力，将威胁能力赋值划分为五个不同的等级，等级 1-5 级，分别对应很低、低、中等、高、很高。

5.4.3.3 数据威胁的频率

频率是数据威胁的属性，评估者应根据经验和（或）有关的统计数据来进行判断。在评估中，需要综合考虑以下几个方面，以形成在各应用场景中各种威胁出现的频率：

- 以往安全事件报告中出现过的威胁及其频率的统计；
- 实际环境中通过检测工具以及各种日志发现的威胁及其频率的统计；
- 实际环境中的监测数据发现的威胁及其频率的统计；
- 近一两年来国际组织发布的对于整个社会或特定行业的威胁及其频率统计，以及发布的威胁预警。

可以对数据威胁出现的频率进行等级化赋值，不同等级分别代表威胁出现的频率的高低。等级数值越大，威胁出现的频率越高。

数据威胁频率赋值划分为五个不同的等级，等级 1-5 级，分别对应很低、低、中等、高、很高。

表 3 提供了一种威胁频率的赋值方法。在实际的评估中，数据威胁频率的判断依据可在评估准备阶段根据历史统计或行业判断予以确定，并得到被评估方的认可。

表3 数据威胁频率赋值表

等级	标识	定义
5	很高	出现的频率很高（或≥1 次/周）；或在大多数情况下几乎不可避免；或可以证实经常发生过
4	高	出现的频率较高（或≥ 1 次/月）；或在大多数情况下很有可能会发生；或可以证实多次发生过
3	中等	出现的频率中等（或> 1 次/半年）；或在某种情况下可能会发生；或被证实曾经发生过
2	低	出现的频率较小；或一般不太可能发生；或没有被证实发生过

1	很低	威胁几乎不可能发生；仅可能在非常罕见和例外的情况下发生
---	----	-----------------------------

5.4.3.4 数据威胁发生可能性

数据威胁发生的可能性与数据威胁的动机、能力和频率有关。综合考虑数据威胁的动机、能力、频率等因素，将数据威胁发生可能性分5级，等级1-5级，分别对应很低、低、中等、高、很高。

5.5 脆弱性识别

5.5.1 概述

脆弱性是数据应用场景自身存在的，如没有被数据威胁利用，脆弱性本身不会对数据资产造成损害。如数据应用场景中涉及的信息系统，如存储系统、业务系统足够健壮，数据威胁难以导致安全事件的发生。也就是说，数据威胁是通过利用应用场景中存在的脆弱性，才可能造成数据机密性、完整性、可用性、可控性的损害。相反，如果威胁没有对应的脆弱性，也不会导致风险。因此，组织一般通过尽可能消减数据应用场景的脆弱性，来阻止或消减数据威胁造成的影响，所以脆弱性识别是数据安全风险分析中最重要的一个环节。本阶段评估工作应输出脆弱性报告。

脆弱性识别所采用的方法主要有：问卷调查、工具检测、人工核查、文档查阅、渗透性测试等。

5.5.2 脆弱性分类

脆弱性可从技术和管理两个方面进行审视。技术脆弱性涉及IT环境的物理层、网络层、系统层、应用层等各个层面的安全问题或隐患。管理脆弱性又可分为技术管理脆弱性和组织管理脆弱性两方面，前者与具体技术活动相关，后者与管理环境相关。表4提供了一种脆弱性识别内容的参考。

表4 脆弱性识别内容表

类型	识别对象	识别内容
技术脆弱性	物理环境	从机房场地、机房防火、机房供配电、机房防静电、机房接地与防雷、电磁防护、通信线路的保护、机房区域防护、机房设备管理等方面进行识别
	网络结构	从网络结构设计、边界保护、外部访问控制策略、内部访问控制策略、网络设备安全配置等方面进行识别
	系统软件	从补丁安装、物理保护、用户账号、口令策略、资源共享、事件审计、访问控制、新系统配置、注册表加固、网络安全、系统管理等方面进行识别
	应用中间件	从协议安全、交易完整性、数据完整性等方面进行识别。
	应用系统	从审计机制、审计存储、访问控制策略、数据完整性、通信、鉴别机制、密码保护等方面进行识别
管理脆弱性	技术管理	从物理和环境安全、通信与操作管理、访问控制、系统开发与维护、业务连续性等方面进行识别
	组织管理	从安全策略、组织安全、资产分类与控制、人员安全、符合性等方面进行

		识别
--	--	----

5.5.3 脆弱性属性分析与赋值

5.5.3.1 概述

脆弱性要素属性包括脆弱性可利用性、脆弱性影响严重程度。通过分析数据应用场景中脆弱点可能被利用的访问路径、访问复杂性、鉴别次数判断脆弱性可利用性，应用场景中已部署了安全措施，可视情况调整可利用性等级。通过分析脆弱性对数据机密性、完整性、可用性、可控性影响，判断对数据影响的严重程度。

5.5.3.2 脆弱性可利用性

脆弱性可利用性跟访问路径、访问复杂性、权限要求、用户交互有关，可利用性分5级，等级1-5级，分别对应很低、低、中等、高、很高。

脆弱性可利用性特征如下：

- a) 访问路径。该特征反映了脆弱性被利用的路径，包括：物理访问，本地访问，邻近网络访问，远程网络访问。
- b) 访问复杂性。该特征反映了攻击者能访问目标系统时利用脆弱性的难易程度，可用高、中、低3个值进行度量。
- c) 权限要求。该特征反映了攻击者为了利用脆弱性需要通过目标系统鉴别的要求，可用无、低、高进行度量。
- d) 用户交互。该特征从攻击行为利用脆弱性时是否需要用户交互的条件反映了脆弱性利用的难易程度，可用不需要和需要2个值进行度量。

注：组织或企业可能已部署了预防性安全措施，可视具体情况调整脆弱性的可利用性。

5.5.3.3 脆弱性影响严重程度

脆弱性对数据的影响严重程度从对数据机密性、完整性、可用性和可控性四方面影响分析，影响严重程度分5级，等级1-5级，分别对应很低、低、中等、高、很高。

脆弱性对数据的影响程度如下：

- a) 机密性影响。该特征反映了脆弱性被成功利用时对数据机密性的影响，可用完全泄密、部分泄密、不泄密3个值进行度量。
- b) 完整性影响。该特征反映了脆弱性被成功利用时对数据完整性的影响，可用完全修改、部分修改、不能修改3个值进行度量。
- c) 可用性影响。该特征反映了脆弱性被成功利用时对数据可用性的影响，可用完全不可用、部分可用、可用性不受影响3个值进行度量。
- d) 可控性影响。该特征反映了脆弱性被成功利用时对数据可控性的影响，可用完全不可控、部分可控、可控性不受影响3个值进行度量。

注：组织或企业可能已部署了保护性安全措施，可视具体情况调整脆弱性对数据的影响严重程度。

5.6 已有安全措施识别

安全措施可以分为预防性安全措施和保护性安全措施两种。预防性安全措施可以降低数据威胁利用脆弱性导致安全事件发生的可能性，如威胁情报系统、入侵检测系统；保护性安全措施可以减少因安全事件发生后对数据、业务或组织造成的影响。

以数据威胁为核心识别组织已有安全措施，在数据威胁识别的同时，评估人员应对已采取的安全措施进行识别。在识别脆弱性的同时，评估人员应对已有安全措施的有效性进行确认。安全措施的确切应评估其有效性，即是否真正地抵御了数据威胁，降低了应用场景的脆弱性。

已有安全措施确认与脆弱性识别存在一定的联系。一般来说，安全措施的使用将减少系统技术或管理上的脆弱性，已有安全措施在脆弱性分析过程，分别影响脆弱性可利用性与脆弱性影响严重程度的赋值。

本阶段应输出已有安全措施分析报告。

5.7 数据安全威胁与脆弱性利用关系

脆弱性能被威胁成功利用，才能形成风险，并不是所有的脆弱性都能被威胁成功利用。附录C给出了数据威胁与脆弱性的利用关系示例。

5.8 风险分析与评价

5.8.1 概述

本节主要描述数据安全风险分析过程与模型、风险计算方法、风险结果评价、风险分析报告。根据风险识别过程中得到的基本要素及其属性作为输入，通过风险计算过程得到风险值，同时描述如何评价风险计算结果，并指导输出风险评估报告文档。

随着风险分析研究的深入，为了提高数据安全风险评估工作的效率和结果的正确性，风险评估工作应该有智能化的风险评估工具辅助风险评估工作。

5.8.2 风险分析模型

数据安全风险评估模型如图4所示，在完成了数据资产识别、数据应用场景识别、数据威胁识别、脆弱性识别，以及对已有安全措施确认后，将采用适当的方法与工具确定数据威胁利用脆弱性导致安全事件发生的可能性，以及安全事件发生对组织的影响，得到安全风险。

数据安全风险分析的主要过程为：

- 根据数据威胁与脆弱性利用关系，结合数据威胁发生可能性与脆弱性可利用性确定安全事件发生的可能性；
- 根据脆弱性影响严重程度及数据重要程度确定安全事件影响严重程度；
- 根据安全事件发生的可能性以及安全事件影响严重程度，确定被评估数据资产在该应用场景的风险；

d) 综合数据资产在各应用场景中风险，确定数据资产的风险。



图4 数据安全风险分析模型

5.8.3 风险计算

5.8.3.1 计算安全事件发生的可能性

根据待评估数据威胁、脆弱性可利用性情况，计算威胁利用脆弱性导致安全事件发生的可能性，即：安全事件发生的可能性 $=L(\text{数据威胁发生可能性}, \text{脆弱性可利用性})=L(t, V_a)$ 。

其中， L 表示安全事件发生可能性计算函数； t 表示数据威胁发生可能性，根据数据威胁的动机、能力和频率综合赋值； V_a 表示脆弱性可利用性，由脆弱性和已有安全措施综合分析计算确定。

5.8.3.2 计算安全事件一旦发生的影响

根据数据重要程度及脆弱性影响严重程度，计算安全事件一旦发生后的对数据、业务及组织造成的影响，即：安全事件的损失 $=F(\text{数据重要程度}, \text{脆弱性影响严重程度})=F(d, V_b)$ 。

其中， F 表示安全事件影响程度计算函数； V_b 表示脆弱性影响严重程度，由脆弱性和已有安全措施综合分析计算确定； d 表示数据资产重要程度。

部分安全事件的发生造成的损失不仅仅是针对该数据资产本身，还可能影响业务连续性、组织声誉，造成经济损失等；不同安全事件的发生对业务与组织造成的影响也是不一样的。在计算某个安全事件的影响时，应对组织的影响也考虑在内。

5.8.3.3 计算风险值

根据计算出的安全事件发生的可能性以及安全事件的影响程度，计算风险值，即：

风险值 $=R(\text{安全事件发生可能性}, \text{安全事件影响})=R(L(t, V_a), F(d, V_b))=R(D, T, V, C)$ 。其中， R 表示安全风险计算函数； D 表示数据资产； T 表示数据威胁； V 表示脆弱性； C 表示已采用的安全措施。

5.8.3.4 计算数据资产面临的风险值

通过上述方法对数据应用场景进行计算得出风险值 R 。数据资产风险值计算以下面范式形式化加以说明：数据资产风险值 $=R_d(R_1, R_2, \dots, R_n)$ 。其中 R_d 是数据资产风险值计算函数，可采用加权平均或其他计算函数 $R_1, R_2, \dots, R_n$ 是不同数据应用场景的风险值。

评估人员可根据自身情况选择相应的风险计算方法计算风险值，计算方法包括定量计算与定性计算两种。其中定量计算方法如矩阵法、相乘法：矩阵法通过构造一个二维矩阵，形成安全事件发生的可能性与安全事件影响之间的二维关系；相乘法通过构造经验函数，将安全事件发生的可能性与安全事件影响进行运算得到风险值。矩阵法和相乘法的风险计算示例可参考GB/T 20984-2007《信息安全技术 信息安全风险评估规范》附录A。

5.8.4 风险结果评价

组织应在考虑组织目标、国家法律法规要求及行业背景和特点的基础上，建立风险准则，以实现风险的 control 与管理，根据风险准则判定风险是否可以接受。

评估实施单位应根据所采用的风险计算方法，计算数据资产面临的风险值，并根据风险评价准则对风险计算结果进行等级处理。表5提供了一种风险等级划分方法，将业务的数据资产面临的安全风险划分为五级，每个等级代表了相应风险的严重程度，等级越高，风险越高。

表5 数据资产等级划分表

等 级	标 识	描 述
5	很高	一旦发生将对业务或组织产生非常严重而深远的影响，对组织信誉严重破坏，严重影响业务或组织的正常运行，产生非常严重的经济损失或社会影响
4	高	一旦发生将对业务、其他业务或组织产生较大的影响，在一定范围内给业务或组织的经营、组织信誉造成损害，产生较大的经济损失或社会影响
3	中等	一旦发生将对业务或组织运行、组织信誉造成一定的影响，但对经济或社会的影响不大，不影响其他业务或对其他业务影响程度不大
2	低	一旦发生造成的影响程度较低，一般仅限于业务、组织内部或数据资产本身，通过一定手段很快能解决
1	很低	一旦发生造成的影响低微

5.8.5 风险评估报告

风险评估报告是风险分析最终交付的产物，记录风险评估的整个过程以及结果。应该至少包括这几方面内容：

- a) 简介
 - 1) 风险评估报告的目的；
 - 2) 风险评估的范围；
 - 3) 风险评估的数据主体。
- b) 风险评估方法
 - 1) 简单介绍风险评估所采用的方法；

- 2) 参与者（如风险评估小组成员）；
- 3) 信息搜集的技术（如所适用的工具、调查表）；
- 4) 风险测量准则的描述（例如一个3*3或者5*5的风险矩阵）。
- c) 风险评估的数据资产
列出风险评估的数据资产范围及数据样例。
- d) 数据应用场景描述
描述系统的情况，包括硬件、软件、系统界面、用户和数据。提供系统之间的图表或者系统输入输出流程图以描述本次风险评估的范围。
- e) 识别出的数据威胁列表，数据威胁评价
- f) 识别出的脆弱性列表及相关已有安全措施列表，脆弱性可利用性与脆弱性影响严重程度评价
- g) 风险评估结果
 - 1) 观察发现的风险列表（威胁源/脆弱点成对出现），应该包括：
 - i. 观察发现的数量及简单的描述（例如：用户系统口令能够被容易的猜解或破译）
 - ii. 威胁源及对应脆弱点的讨论；
 - 2) 发生可能性的讨论及评价影响分析的讨论及评价风险的等级；
 - 3) 可降低风险的推荐的控制措施。
- h) 总结
观察发现的风险的总和，观察发现的风险的概述及相应的风险等级。应对风险的控制措施的建议及说明，指导风险降低过程中控制措施的实施。

6 风险处置

应根据风险接受准则判定风险是否可以接受，对不可接受风险应采取相应的风险处置措施降低风险级别。

风险处置措施应着重针对可能被威胁利用的脆弱性来制定，找出引发不可接受风险的脆弱性，提出具体的风险处置措施。

风险处置措施应包括风险级别、风险描述、风险值、风险处置措施、风险处置步骤、相关责任人、预计时间等。

风险处置措施的制定应考虑以下内容：

- a) 合规需求：组织制定的风险处置措施应符合相关法律法规需求；
- b) 业务需求：数据风险评估的目的是保证组织业务的完整运行，风险处置措施应也和业务需求制定；
- c) 组织建设：组织的建设是保证数据安全的必要手段，应考虑是否设立数据安全保护组织，以完成数据安全保护目标；
- d) 制度流程：必要的制度和规范的流程是保障人员执行数据安全要求的要素之一，其中包括数据安全方针和目标、数据安全策略、数据安全管理办法、数据安全操作指引和相关模板等；

- e) 工具：数据安全不仅仅需要考虑管理手段，配套的技术和工具也是需要考量的，其中包括信息系统、加密算法、工具等；
- f) 人员：人员是执行以上手段的必要要素之一，可以通过招聘或培训的方式提升人员数据安全保障能力。

风险处置措施宜参考以下方式：

- a) 控制风险：实施有效控制，降低威胁发生的现实可能性和造成的影响，将风险降低到可以接受的等级，包括：减少威胁，即通过有效实施风险控制措施，避免威胁发生，从而保护信息资产；减少脆弱点，即通过有效实施风险控制措施，减少脆弱点。如采取适当的技术措施，对员工实施安全教育培训，强化员工的安全意识和安全操作能力；降低影响，即通过预防性措施降低威胁发生后可能造成的损失。如对重要信息的备份、制定业务连续性计划等；
- b) 转嫁风险：将风险全部或部分地转移到其他责任方，如通过购买保险或外包等方式将风险转移给他方；
- c) 避免风险：远离风险环境或采取与风险环境相隔离的措施。如将有高安全要求的设备或业务活动设置在高安全区中，增加特殊防护手段防止设备或业务活动遭受威胁的影响；
- d) 接受风险：接受风险的决策。

7 残余风险评估

残余风险处理是风险评估活动的延续，是被评估组织按照风险安全整改建议全部或部分实施整改工作后，对仍然存在的安全风险进行识别、控制和管理的活动。

残余风险评估的目的是对数据安全仍存在的残余风险进行识别、控制和管理。如某些风险在完成适当的安全措施后，残余风险的结果仍处于不可接受的风险范围内，应考虑进一步增强相应的安全措施。

对于已完成安全加固措施的数据，为确保安全措施的有效性，可进行残余风险评估，评估流程及内容应做有针对性的剪裁。

残余风险评估实施应遵循：

- a) 依据组织的风险评估准则进行残余风险评估，判断是否已经降至可接受水平，为风险管理提供输入；
- b) 残余风险仍处于不可接受的风险范围内，则应由管理层依据风险接受原则考虑是否接受此类风险或增加更多的风险控制措施；
- c) 应定期开展残余风险再评估，评估结果应作为风险管理重要输入。

附录 A

(资料性附录)

数据安全有关法律法规及标准参考表

类型	名称
法律	《中华人民共和国网络安全法》
	《中华人民共和国国家安全法》
	《中华人民共和国民法总则》
	《中华人民共和国刑法》
	《中华人民共和国治安管理处罚法》
	《全国人大常委会关于加强网络信息保护的决定》
	《全国人大常委会维护互联网安全的决定》
	《中华人民共和国居民身份证法》
	《中华人民共和国护照法》
	《中华人民共和国消费者权益保护法》
	《中华人民共和国电子商务法》
	《中华人民共和国测绘法》
行政法规	《中华人民共和国计算机信息系统安全保护条例》
	《中华人民共和国电信条例》
	《计算机信息网络国际联网安全保护管理办法》
	《互联网信息服务管理办法》
	《征信业管理条例》
	《地图管理条例》
部门规章	《电信和互联网用户个人信息保护规定》
	《规范互联网信息服务市场秩序若干规定》
	《互联网电子邮件服务管理办法》
	《通信短信息服务管理规定》
	《互联网域名管理办法》
	《个人信用信息基础数据库管理暂行办法》
规范性文件	《促进大数据发展行动纲要》
	《政务信息资源共享管理暂行办法》
	《国务院办公厅关于加强金融消费者权益保护工作的指导意见》
	《国务院办公厅关于促进和规范健康医疗大数据应用发展的指导意见》
	《国务院办公厅关于深化改革推进出租汽车行业健康发展的指导意见》
	《科学数据管理办法》
	《移动智能终端应用软件预置和分发管理暂行规定》
	《即时通信工具公众信息服务发展管理暂行规定》
	《信息安全等级保护管理办法》
	《网络安全等级保护条例（征求意见稿）》
	《关于金融机构做好个人金融信息保护的通知》

	《中国人民银行金融消费者权益保护实施办法》
	《中国人民银行关于加强跨境金融网络与信息服务管理的通知》
	《国家健康医疗大数据标准、安全和服务管理办法（试行）》
	《人口健康信息管理办法（试行）》
	《网络预约出租汽车经营服务管理暂行办法》
	《教育部机关及直属事业单位教育数据管理办法》
司法解释	《两高关于办理侵犯公民个人信息刑事案件适用法律若干问题的解释》
国家标准	《信息安全技术 个人信息安全规范》
	《信息安全技术 公共及商用服务信息系统个人信息保护指南》
	《信息安全技术 移动智能终端个人信息保护技术要求》
	《信息安全技术 大数据安全管理指南》
	《信息安全技术 大数据服务安全能力要求》
	《信息安全技术 数据安全能力成熟度模型》
	《信息安全技术 数据交易服务安全要求》
	《信息安全技术 安全保护等级划分准则》
	《信息安全技术 数据库管理系统安全技术要求》
	《信息安全技术 移动智能终端数据存储安全技术要求与测试评价方法》
行业标准	《电信和互联网服务 用户个人信息保护技术要求》
	《电信和互联网服务 用户个人信息保护技术要求 即时通信服务》
	《移动用户个人信息管理业务总体技术要求》
	《移动用户个人信息管理业务 终端技术要求》
	《电信和互联网用户个人电子信息保护通用技术要求和管埋要求》
	《电信和互联网服务 用户个人信息保护 定义及分类》
	《电信和互联网服务 用户个人信息保护分级指南》
	《移动智能终端上的个人信息保护技术要求》
	《电信和互联网服务 用户个人信息保护技术要求 移动应用商店》
	《电信和互联网服务 用户个人信息保护技术要求 电子商务服务》
	《电信运营商的大数据应用业务安全技术要求》
	《互联网新技术新业务安全评估要求 大数据技术应用与服务》
	《通用数据加密模块接口要求》
	《第三方灾备数据交换技术要求》
	《通信存储介质（SSD）加密安全技术要求》
	《集中式远程数据备份技术要求》
	《使用 cookie 进行互联网数据采集的安全性要求》
	《网络虚拟身份数据存储与交换技术要求》
	《云环境下数据库安全机制与弱点分析技术研究》
	《基于域名系统（DNS）的 IP 安全协议（IPSec）认证密钥存储技术要求》
	《面向云服务的数据安全标记规范》

附录 B

(资料性附录)

数据应用场景中的业务流程或使用流程举例

数据应用场景包括主业务调用数据的场景、数据被其他业务系统调取的场景、对组织外部提供数据的场景（合作业务）、员工访问数据的场景、第三方服务人员访问数据的场景等。每类数据应用场景可能的业务流程或使用流程示例如表 B.1。

表B.1 数据应用场景中的业务流程或使用流程举例

应用场景分类	应用场景举例	业务流程或使用流程示例
业务	a) 数据分析业务： 向客户提供数据分析服务。涉及数据分析系统、数据基础平台、数据基础设施管理系统等。	流程示例： 公共数据平台需求申请→需求审批→访问平台→数据调取→数据加工→结果存储→结果展示或向客户提供
	b) 广告推送业务： 向用户提供广告推送。涉及信息系统包括广告系统、用户行为分析系统。	流程示例： 广告获取→推送方案设计→用户行为分析→发现目标用户→广告推送→效果反馈
	c) 计费结算业务： 统计用户使用服务情况，并根据用户定价结算用户服务费用。	流程示例： 用户计费数据采集→计费数据处理→批价
	d) 网络运维： 由基础网络部门负责，为所有网络基础设施提供基础服务和安全服务。	流程示例： 管理员权限申请审批→接入运维系统、机房或设备→访问系统→退出→权限注销
人员访问内部系统数据的场景	a) 本业务人员调取数据的场景	流程示例： 业务人员进组→开通账号与权限→系统与数据访问→账号注销→业务人员离组
	b) 非本业务员工调取数据的场景	流程示例： 非本业务员工提出数据访问需求申请→需求审批→开通账号与权限→数据访问→需求结束→审计→账号注销
	c) 第三方人员调取数据的场景	流程示例 1： 第三方人员需求申请→为第三方人员分配账号与权限→第三方人员驻场服务→数据访问→离场→账号注销 流程示例 2： 为第三方人员分配账号与权限→第三方人员非驻场服务→VPN 登录→数据访问→离场→账号注销
业务系统访问内部系统数据的场景	a) 组织内其他业务系统调取数据的场景	流程示例： 业务需求申请→需求受理审批→开放访问接口→分配账号、配置权限→访问系统→调取数据→需求完成→删除账号权限→关闭接口
	b) 组织外部系统调取数据的场景	流程示例： 外部需求申请→需求受理审批→分配账号、权限、访问接口→访问系统→调取数据→需求完成→删除账号、关闭接口

附录 C

(资料性附录)

数据威胁与脆弱性利用关系示例

脆弱性能被威胁成功利用，才能形成风险，并不是所有的脆弱性都能被威胁成功利用。威胁与脆弱性的利用关系示例如表 C.1。

表 C.1 数据威胁与脆弱性利用关系示例

数据安全威胁	脆弱性
恶意代码注入	采集/处理/存储组件存在漏洞。
数据无效写入/数据污染	数据入库时无校验机制。
传输信道被监听/遭到中间人攻击	数据以明文传输； 敏感元数据未加密或脱敏。
物理环境变化/自然灾害/硬件故障	无数据备份/恢复机制； 云计算等第三方平台缺乏安全保障机制。
越权访问与数据资源滥用	内部员工、合作方员工安全管理存在漏洞； 内部员工、合作方员工违规操作； 人员或其他业务系统访问权限粒度太粗、访问授权有误； 系统或组件存在漏洞。
数据分类分级、标记错误	数据分类分级无标准； 系统错误。
数据篡改	采集/处理/存储组件存在漏洞； 缺乏操作指导，有权限员工操作错误或配置错误； 内部员工或第三方合作人员越权操作。
数据窃取	数据以明文传输； 在数据库服务器、文件服务器、员工终端等存储系统上执行后门、病毒、木马、蠕虫、窃听软件、间谍软件等恶意工具或代码； 数据失效或业务关闭后，遗留了敏感数据仍然可以被访问或数据销毁不彻底，可被技术性恢复； 内部员工或第三方合作人员越权获取； 关键岗位员工被收买窃取数据，安全意识培训机制、考核机制、数据行为审核手段、审计监控措施存在漏洞。
数据不可控	内部员工与第三方合作人员的数据安全管理机制存在漏洞； 办公终端缺乏技术监控手段； 对第三方合作机构缺少协议或数据安全相关条款约束； 对第三方合作机构与人员部署技术监控措施。

参考文献

- 【1】 GB/T 35273-2017 信息安全技术 个人信息安全规范
- 【2】 GB/T XXXXX-XXXX 信息安全技术 个人信息安全影响评估指南
- 【3】 GB/T XXXXX-XXXX 信息安全技术 数据出境安全评估指南
- 【4】 GB/T 31509-2015 信息安全技术 信息安全风险评估实施指南
- 【5】 GB/T 20984-2007 信息安全技术 信息安全风险评估规范
- 【6】 GB/T XXXXX-XXXX 信息安全技术 公共及商用服务信息系统 个人信息保护指南
- 【7】 GB/T 30279-2007 信息安全技术 安全漏洞等级划分指南
- 【8】 YD/T 2692-2014 电信和互联网用户个人电子信息保护通用技术要求和管埋要求
- 【9】 YD/T 1730-2008 电信网和互联网安全风险评佔实施指南
- 【10】 NIST SP 800-30 风险评估报告要点示例